

SECURITY.md — Synapse Layer Security Architecture

Executive Summary

Synapse Layer implements **Zero-Knowledge Architecture** where:

- You own encryption keys; we never have access
- All PII removal happens on your machine (client-side)
- Encrypted blobs stored at rest
- Immutable audit trail of all operations
- **GDPR, LGPD, HIPAA compliant**

Security Standard: Banking-Grade Infrastructure (Padrão Bancário BR)

Encryption & Key Management

AES-256-GCM Encryption

Algorithm: AES-256 in Galois Counter Mode (GCM)

- **Key Size:** 256 bits (32 bytes)
- **IV:** 96 bits (12 bytes), randomly generated per message
- **Auth Tag:** 128 bits (16 bytes) — Verifies integrity & authenticity
- **Mode:** GCM provides both confidentiality and authenticity

Why GCM?

- Authenticated encryption (prevents tampering)
- Parallelizable (fast)
- Industry standard (TLS 1.3, SSH)
- Protects against chosen-ciphertext attacks

Key Derivation (PBKDF2)

Algorithm: PBKDF2-SHA256

- **Iterations:** 210,000 (NIST 2023 minimum)
- **Salt:** 32 bytes, randomly generated
- **Hash Function:** SHA-256
- **Output Key Length:** 32 bytes (256 bits)

Process:

```
user_password + random_salt → PBKDF2(210k iterations) → 256-bit encryption key
```

Why 210k iterations?

- Recommended by NIST SP 800-132 (2023)
- Resistant to GPU/ASIC attacks
- Computational cost: ~100ms per derivation (acceptable for user experience)
- Updated from previous standard (600k+) to balance security and UX

Security Properties:

- **Time-based:** Each derivation takes ~100ms, making brute-force impractical
 - **Space-hard:** Resistant to parallel GPU attacks
 - **Unique per user:** Different salt prevents rainbow table attacks
-

Client-Side Sanitization

PII Detection & Removal

Before transmission to server, client removes:

1. Personally Identifiable Information

- Names (flagged but not automatically removed)
- Email addresses: john@example.com
- Phone numbers: +55 11 99999-8888
- Home addresses

2. Financial Information (CRITICAL)

- Credit card numbers: 1234-5678-9012-3456
- Bank account numbers
- SSN/CPF: 123-45-6789 , 123.456.789-00

3. Health Information (CRITICAL)

- Medical diagnoses
- Medication names
- Hospital names

4. Security Credentials (CRITICAL)

- Passwords
- API keys: sk_test_... , ghp_...
- OAuth tokens

5. Authentication Factors

- 2FA codes
- Biometric data

Sanitization Process

```
# Input
user_content = "My email is john@example.com and SSN is 123-45-6789"

# SynapseSanitizer.sanitize_content()
# Step 1: Regex detection
# Step 2: PII removal
sanitized_content = "My email is [EMAIL_REDACTED] and SSN is [SSN_REDACTED]"

# Output
risk_score = 0.3 # CRITICAL items found
pii_count = 2
is_safe = False
ner_hints = ["email:12", "ssn:48"]

# Sanitized version sent to server (encrypted)
```

Why Client-Side?

- **Privacy:** We never see your raw PII
- **Control:** You decide what gets removed
- **Speed:** No round-trip to server
- **Regulation:** Compliance with LGPD § 5.10 and GDPR Article 5

Intent Validation & Self-Healing

IntentCategory Classification

USER_PROFILE	→ Settings, preferences (NORMAL)
CONVERSATION	→ Dialog, chat (NORMAL)
DECISION	→ Commitments, goals (NORMAL)
KNOWLEDGE	→ Facts, learning (NORMAL)
PREFERENCE	→ Tastes, likes (NORMAL)
MEDICAL	→ Health records (AUTO-CRITICAL)
FINANCIAL	→ Payments, accounts (AUTO-CRITICAL)
LEGAL	→ Contracts, disputes (AUTO-CRITICAL)
SECURITY	→ Passwords, tokens (AUTO-CRITICAL)

Confidence Threshold

- **Minimum Valid Confidence:** 0.85 (85%) — **Immutable**
- **Critical Keywords:** Auto-promote to SECURITY
- emergency, urgent, breach, attack, fraud
- **Self-Healing:** If confidence 0.5–0.85, detect context and upgrade

Example:

Input: "I have health issues and need medical help"
 Confidence (raw): 0.65
Self-Healing: Detect "health" + "medical" → Upgrade to MEDICAL (auto-CRITICAL)
 Final: confidence=0.75, category=MEDICAL, is_critical=True

Differential Privacy

Aggregation Protection

When querying across multiple memories (e.g., "What are my common health concerns?"), noise is added to prevent individual data leakage:

Actual **aggregate**: [50 users with anxiety, 30 with insomnia, 20 with depression]
 With DP ($\epsilon=1.0$): [51 users with anxiety, 28 with insomnia, 22 with depression]

Epsilon (Privacy Budget)

- $\epsilon = 1.0$: Strong privacy (data not identifiable)
- $\epsilon = 0.1$: Weaker privacy (more accurate statistics)

- **Default:** $\epsilon = 0.5$ (balanced)

How it works:

- Laplace mechanism adds Laplacian noise proportional to $1/\epsilon$
- Lower ϵ = stronger privacy = more noise
- Higher ϵ = weaker privacy = less noise

Neural Handover™ Security

Lifecycle of a Handover

1. Agent A (Claude) initiates handover
 - ☐ Extracts relevant memories
 - ☐ Creates summary
 - ☐ Signs with private key
2. Handover signature created
 - ☐ Algorithm: HMAC-SHA256
 - ☐ Key: Agent A's private key
 - └ Message: summary_content + timestamp + target_agent_id
 - └ Signature: 32-byte proof
3. Handover transmitted to Agent B (GPT-4)
 - └ Encrypted with Agent B's public key
 - ☐ TTL: 1 hour (expires)
 - ☐ Single-use token (cannot be replayed)
4. Agent B verifies handover
 - ☐ Verify signature with Agent A's public key
 - ☐ Check timestamp (not expired)
 - ☐ Check target_agent_id matches
 - ☐ Decrypt with private key
 - ☐ Load context into memory
5. Audit log records
 - ☐ Handover initiator (Agent A)
 - ☐ Handover recipient (Agent B)
 - ☐ Timestamp
 - ☐ Memory summary hash
 - ☐ Verification result (success/failed)

Security Properties

- **Authentication:** Only Agent A can sign handovers on its behalf
- **Integrity:** Signature prevents tampering with summary
- **Freshness:** Timestamp + TTL prevent replay attacks
- **Non-Repudiation:** Agent A cannot deny initiating handover
- **Audit Trail:** All handovers logged permanently

Data at Rest Encryption

PostgreSQL Storage

```
CREATE TABLE memories (
  id UUID PRIMARY KEY,
  agent_id UUID NOT NULL,
  encrypted_blob BYTEA NOT NULL,      -- AES-256-GCM ciphertext
  embedding_vector vector(1536) NOT NULL, -- Semantic search vector
  intent_category VARCHAR(50) NOT NULL,
  created_at TIMESTAMP NOT NULL,
  updated_at TIMESTAMP NOT NULL
);

-- Row-Level Security (RLS)
ALTER TABLE memories ENABLE ROW LEVEL SECURITY;
CREATE POLICY agent_isolation
  ON memories
  FOR SELECT
  USING (agent_id = current_user_id());
```

Encryption at Rest

- **Column:** `encrypted_blob` contains AES-256-GCM ciphertext
 - **Key:** Derived from master key + `agent_id`
 - **Encryption:** Happens on client; server stores encrypted bytes
 - **Decryption:** Only client can decrypt (has user's password)
-

Transport Security

HTTPS + TLS 1.3

- **Protocol:** HTTPS (TLS 1.3)
- **Ciphers:** AES-256-GCM or ChaCha20-Poly1305
- **Certificate Pinning:** Client verifies server certificate (prevent MITM)
- **mTLS:** Client certificate authentication (optional for enterprise)

API Authentication

- **Bearer Token:** Session token (short-lived, ~1 hour)
 - **Refresh Token:** Long-lived token for getting new session (stores securely)
 - **API Key:** For programmatic access (rotate regularly)
-

Compliance

GDPR (General Data Protection Regulation)

- ✓ **Data Minimization:** PII detected and removed client-side
- ✓ **Encryption:** AES-256-GCM at rest + TLS in transit
- ✓ **Purpose Limitation:** Data used only for memory/retrieval
- ✓ **Right to Deletion:** User can request permanent deletion (audit log erased after 1 year)

- ✓ **Right to Access:** User can export all encrypted memories
- ✓ **Data Controller:** User owns the data; Synapse is processor

Relevant Articles:

- Article 5: Principles (lawfulness, fairness, transparency, integrity)
- Article 32: Security of processing
- Article 35: Data Protection Impact Assessment

LGPD (Lei Geral de Proteção de Dados — Brazil)

- ✓ **Consentimento Explícito:** User opt-in required
- ✓ **Segurança:** AES-256-GCM encryption per § 5.10
- ✓ **Transparência:** Clear privacy policy and data usage
- ✓ **Direito de Acesso:** User can request data export
- ✓ **Direito de Exclusão:** User can delete memories permanently
- ✓ **Regime de Responsabilidade:** Synapse liable for breaches

Padrão Bancário: Implemented according to Central Bank of Brazil (BACEN) standards

HIPAA (Health Insurance Portability and Accountability Act)

- ✓ **Encryption:** AES-256-GCM for all health data
 - ✓ **Access Controls:** User-based encryption (PBKDF2)
 - ✓ **Audit Trail:** Immutable log of all access
 - ✓ **Business Associate Agreement:** Required for healthcare apps
 - ⚠ **Key Management:** User responsible for managing encryption keys
-

Threat Model & Mitigation

Threat	Probability	Impact	Mitigation
Plaintext data breach	HIGH	CRITICAL	AES-256-GCM encryption at rest
SQL injection	MEDIUM	HIGH	Parameterized queries, ORM (Prisma)
API key leak	MEDIUM	CRITICAL	Sanitize + remove before transmission
Man-in-the-middle	LOW	HIGH	TLS 1.3 + certificate pinning
Brute force password	LOW	MEDIUM	PBKDF2 210k iterations + rate limiting
Insider threat	LOW	CRITICAL	Zero-knowledge (employees can't decrypt)
Replay attack	LOW	MEDIUM	Handover TTL + single-use tokens
Denial of service	MEDIUM	MEDIUM	Rate limiting + DDoS protection

Best Practices for Users

1. Manage Passwords:

- Use strong, unique passwords (20+ chars)
- Never share your password
- Use password manager

2. Sanitization:

- Review sanitized content before storing
- Don't bypass sanitization deliberately
- Report false negatives

3. Handover:

- Only initiate handovers to trusted agents
- Verify agent identity before accepting handovers
- Review summary before accepting context

4. Audit Log:

- Periodically review access logs

- Enable alerts for suspicious activity
 - Export audit trail annually
-

Responsible Disclosure

If you discover a security vulnerability:

1. **Do NOT** file a public GitHub issue
 2. **Email:** security@synapselayer.org
 3. **Include:**
 - Vulnerability description
 - Reproduction steps
 - Potential impact
 - Suggested fix (optional)
 4. **Timeline:**
 - We respond within 48 hours
 - We aim to patch within 7 days
 - Public disclosure after patch release
-

Security Updates

- **Critical patches:** Released immediately
 - **High-priority fixes:** Within 1 week
 - **General updates:** Monthly security releases
 - **Subscribe:** <https://synapselayer.org/security>
-

Questions?

Email: security@synapselayer.org

Last Updated: April 2026

Version: 1.0.3